

Identity and Access Management (IAM) Audit

IDENTITY AND ACCESS MANAGEMENT (IAM) INTERNAL AUDIT

Audit Period: Q2 2026 Auditor: Elena Rostova, Internal Risk & Compliance System Scope: Active Directory, AWS IAM, GitHub Enterprise

Executive Summary: In accordance with SOC 2 Type II compliance mandates, an internal audit of Identity and Access Management (IAM) controls was conducted. The audit focused on the Principle of Least Privilege (PoLP), termination offboarding procedures, and multi-factor authentication (MFA) enforcement across critical engineering systems.

Audit Findings:

- 1. Stale Accounts (Medium Risk):** We identified 12 active AWS IAM user accounts that have not logged in or rotated access keys in over 90 days. Cross-referencing with HR records revealed that 3 of these accounts belong to former contractors whose contracts expired in May. ***Remediation*:** Implement an automated Lambda script to disable IAM accounts after 60 days of inactivity and delete them after 90 days.
- 2. Over-Privileged Roles (High Risk):** The `Developer-Baseline` IAM policy attached to all Junior Engineers currently contains the `s3:\*` permission wildcard. This allows broad, destructive actions (such as bucket deletion) across all S3 buckets, including production databases. ***Remediation*:** The policy must be immediately restricted to `s3:GetObject` and `s3:PutObject` scoped specifically to development-tier buckets using Resource ARNs.
- 3. MFA Enforcement Bypass (High Risk):** While SSO with MFA is enforced for web console access, we discovered that programmatic access via AWS CLI using long-lived access keys bypasses the MFA requirement. ***Remediation*:** Refactor the AWS authentication flow to require developers to assume roles using temporary STS tokens generated via an MFA-authenticated SSO portal (e.g., AWS IAM Identity Center).
- 4. GitHub Access Controls (Low Risk):** Two engineering repositories containing proprietary algorithms lacked branch protection rules, allowing developers to force-push changes to the `main` branch without a pull request. ***Remediation*:** Branch protection rules requiring at least one approving review and a passing CI build have been retroactively applied by the repository admins during the audit.

Conclusion: The findings indicate a drift from our baseline security posture, primarily due to manual provisioning processes. Transitioning to Infrastructure as Code (IaC) for all IAM role definitions is strongly recommended.